

Do you know what your team is sharing with AI?

ChatGPT, Claude, Copilot, and Cursor are already inside your engineering workflow. This 15-point checklist helps you assess — honestly — whether you have visibility into what's leaving your organization through AI prompts. Check what you can answer with evidence, not policy documents.

1 · DISCOVERY — WHAT'S ACTUALLY IN USE

- ☐ **Tool inventory:** We can list the AI tools (incl. browser-based) our employees used in the last 30 days.
- ☐ **Unsanctioned usage:** We can detect AI tools in use that were never approved or reviewed.
- ☐ **Coverage:** Our visibility includes personal accounts on work devices, not just SSO-connected apps.

2 · EXPOSURE — WHAT'S BEING SHARED

- ☐ **Prompt-level awareness:** We know whether source code, API keys, or credentials have appeared in prompts to public AI tools.
- ☐ **Customer data:** We can say with confidence whether customer PII or contract data has been submitted to an AI tool.
- ☐ **File uploads:** We have visibility into documents and spreadsheets uploaded to AI tools, not just typed text.
- ☐ **Historic exposure:** If asked "has our data ever leaked via AI?", we could answer from records — not guesswork.

3 · PREVENTION — WHAT HAPPENS BEFORE SUBMISSION

- ☐ **Point-of-prompt control:** Sensitive content is flagged or blocked *before* a prompt is submitted, not discovered in logs afterward.
- ☐ **Sanitization path:** Employees have a one-click way to strip secrets/PII from a prompt instead of just being told "no".
- ☐ **Developer workflow fit:** Controls work where engineers actually work — browser, IDE, and AI chat tools — without blocking productivity.

4 · GOVERNANCE — CAN YOU DEMONSTRATE IT

- ☐ **Written policy:** We have an AI acceptable-use policy that names specific data categories, not generic "be careful" language.
- ☐ **Enforcement evidence:** We could show an auditor or enterprise customer *how* the policy is enforced, with logs.
- ☐ **Incident playbook:** If sensitive data reached an AI tool today, we know who is notified and what happens next.
- ☐ **Metrics:** We track leak attempts prevented per month — and the trend.
- ☐ **Review cadence:** AI usage and exposure is reviewed at least quarterly with engineering and security leadership.

HOW TO READ YOUR SCORE

12-15 checked: You're ahead of nearly every team we speak with. · **7-11:** You have policy but limited proof — visibility gaps will surface in your next security review. · **0-6:** AI usage in your org is effectively unmonitored; one prompt is all it takes.